

Quantum-Resistant Security: PQC Readiness and Research Challenges (Invited)

Ashish Kundu, Ramana Kompella

Cisco Research

San Jose, California, 95134, USA

Email: (ashkundu, rkompell)@cisco.com

Abstract—“What is your PQC-readiness” - in this paper, we have explored this problem, some of the key challenges to address it and how ciphersuite dependency graphs along with observability plays a vital role in addressing some of those challenges. Quantum computing capabilities are evolving fast and on course to develop a cryptographically relevant quantum computer (CRQC). With that several widely used classical cryptography protocols such as RSA are poised to be broken in the next few years. NIST has announced three cryptography protocols as part of the first batch of post-quantum cryptography standards. However, implementation and adoption of quantum-resistant cryptography is a hard problem given the complexities of today’s internet and computing stack. Our work has led to development of algorithms and a system - Quartz (Quantum Risk and Threat Analyzer) for observability for quantum vulnerabilities for cryptography suites, where they are used, and analyzing their risks. In that context, we used observability, and the concept of ciphersuite dependency graphs in order to determine use of quantum-unsafe cryptography, and its influence on cryptography supply chain, and generation of cryptography bill of materials (CBOM).

1. Introduction

Quantum computing is evolving rapidly over the last few years. With enough computing power, such systems can be used to break widely used cryptography protocols. Shor’s algorithm [9], [10] can be used to break widely used public key cryptography such as RSA, and Diffie-Hellman. Grover’s algorithm [7] can be used to weaken the strength of cryptography by reducing the search space by half, and thus can lead to algorithms such as AES-128 to be broken.

Transitioning to post-quantum cryptography (PQC) [4], [8] is essential to remain quantum-safe, and PQC-readiness assessment is a key step in that process. Such an assessment is somewhat different than regular security assessments. In this paper, we study this problem, develop the essential building blocks for PQC-readiness assessment and briefly (due to space constraints) discuss an approach we have used to develop a system called Quartz.

2. Background: Quantum Threats and PQC

2.1. Threats to Cryptography

Shor’s quantum algorithms. [9], [10] for integer factorization can be used to break public key cryptography techniques such as RSA, Diffie-Hellman based on discrete logarithm and elliptic curve Diffie-Hellman key exchange, and related other such cryptography schemes. Public key infrastructure, digital certificates, digital signatures and derivatives, and wherever public key cryptography is used directly or indirectly, will be broken once there is enough quantum computing capability to implement Shor’s algorithm.

Grover’s quantum search algorithm. [7] reduces the search space by half and thus reduces the strength of security of cryptography protocols by the same proportion.

GEECM. [5] quantum scheme uses Grover’s search algorithm with the Elliptic curve factorization in order to enable more efficient integer factorization, and is claimed to be faster than Shor’s algorithm.

2.2. Security Threats

Cryptography acts as a building block for enabling confidentiality and integrity. With the use of quantum of algorithms to solve mathematically hard problems used by cryptosystems, the threats to cryptography opens up several types of security threats before, and after the realization of cryptographically relevant quantum computer (CRQC). With the realization of CRQC, almost all attacks that exploit classical cryptography weaknesses is relevant in the context of quantum threats. Some specific threats that have emerged are as follows:

Harvest-now-decrypt-later (HNDL). HNDL is an immediate threat now even when CRQC is not publicly known to exist. Also known as store-now-decrypt-later (SNDL), HNDL involves two steps: (i) storage of data encrypted using quantum-unsafe cryptography (flowing through a traffic, stored, or being computed), and (ii) the stored encrypted data is then decrypted by breaking the cryptography using CRQC and the quantum algorithms to recover the plaintext of the ciphertext.

Version downgrade attacks. During handshaking and negotiation of ciphersuites for session encryption such as in TLS, versions are downgraded to quantum-unsafe ciphersuites (lower/past versions refer to such ciphersuites) are presented and selected for session encryption.

Route re-direction attacks. Traffic and encrypted data in motion is redirected to a different route that facilitates harvest/storage of data for HNDL or facilitate decryption.

2.3. Post-Quantum Cryptography (PQC)

The study, design and development of cryptography schemes based on mathematical problems that are hard to be solved not only by classical computing systems but also quantum computing systems such as CRQC is referred to post-quantum cryptography (PQC). In general, PQC schemes refer to those that are developed as part of standards by NIST and/or other cryptography standardization processes and organizations.

NIST has standardized three cryptography schemes [2]:

- FIPS 203: ML-KEM - Module-Lattice-Based Key-Encapsulation Mechanism (based on CRYSTALS-Kyber) is for general encryption, supports short keys and efficiency in the speed of operation.
- FIPS 204: ML-DSA - Module-Lattice-Based Digital Signature Algorithm (based on CRYSTALS-Dilithium) is for digital signatures.
- FIPS 205: SLH-DSA - stateless hash-based digital signature algorithm (based on Sphincs+) as a backup against any future vulnerabilities in ML-DSA.

NIST is continuing to work on future standardization of more cryptography schemes [3]:

- FIPS 206: FN-DSA - FFT (fast-Fourier transform) over NTRU-Lattice-Based Digital Signature Algorithm (based on FALCON).
- HQC: Hamming Quasi-Cyclic is based on mathematical problems different than .
- FIPS 205: SLH-DSA - stateless hash-based digital signature algorithm (based on Sphincs+) as a backup against any future vulnerabilities in ML-DSA.

There are several other standardization bodies across the world in different countries that have announced or are working on their PQC standards and regulatory requirements. Some of them have standardized quantum-resistant security techniques through augmentation of PQC schemes with other measures such as key exchange protocols.

2.4. Key Concepts and Terms

Threats to cryptography based on the quantum algorithms can be enabled when these algorithms are implemented on a quantum computing system such as CRQC. In this context, let us introduce some of the related concepts and terminology first. Terminologies are on and related to quantum-readiness, PQC-readiness, quantum-safe, quantum-resistant, quantum-resilient.

Cryptographically Relevant Quantum Computer. CRQC refers to a quantum computing system that can be used to implement quantum algorithms such as Shor's, Grover's, and GEECM algorithms and other such quantum algorithms developed in future such that such implementations can practically solve quantum-solvable problems used by cryptography, and break the associated cryptography protocols efficiently (with polynomial time complexity).

Quantum-solvable problems. Mathematical problems that are hard to be solved by classical computing systems, but can be solved efficiently by a quantum computing system with the help of quantum algorithm(s) as mentioned earlier in an efficient (i.e., polynomial time complexity) are referred to as quantum-solvable problems. Relations of quantum-solvable problems with quantum complexity classes such as BQP [6], is out of scope for this paper. CRQCs target such problems that are used for cryptography and solve them thus breaking the associated cryptography schemes. Shor's algorithm for example solves the quantum-solvable problem of prime factorization to break RSA. We refer to problems that are hard for both classical and quantum systems as quantum-unsolvable problems.

Quantum-unsafe cryptography. Cryptography schemes and protocols that are based on quantum-solvable problems are referred to as quantum-unsafe cryptography.

Quantum-safe cryptography. Cryptosystems and protocols that are based on hard problems that are not quantum-solvable are termed as quantum-safe. An entity is Quantum-safe if and only if (i) the assets are quantum-ready, and (ii) the quantum-resistance capabilities of some or all of these systems alongwith other additional systems are activated and used together in a collective manner in order to protect the end-to-end system from the quantum threats due to CRQCs to its cryptography. (iii) Else: such an entity is called as quantum-ready but not quantum-safe, nor quantum-resistant.

"Provably quantum-safe" cryptography. Cryptography schemes, that are provably secure against CRQC are termed as provably quantum-safe.

Cryptographic agility. A cryptography scheme when used in a configurable manner that enables (static or dynamic) configuration of its security strength, security parameters and other cryptography functions is called agile cryptography scheme. Moreover, a system that allows (static or dynamic) configuration of selection of cryptography schemes, and their configuration, is referred to as a cryptographically agile system.

Hybrid cryptography. A combination of PQC schemes and other non-PQC schemes including pre-quantum algorithms, or quantum cryptography may provide desired security guarantees. Such combination is termed as hybrid cryptography.

Quantum-resistant security. Quantum-resistant security of a system supports defense mechanisms that augments PQC, and hybrid cryptography so that the system is protected from quantum threats to the desired levels of security perhaps stronger than what is guaranteed by PQC.

3. PQC-Readiness Assessment

Cryptography is scattered across the depth and breadth of computing stack of systems, distributed systems, and interconnected components. In order to protect from the security threats described in Section 2, the associated systems and entities should adopt quantum-safe cryptography by using PQC schemes, and/or hybrid schemes. Such quantum-resistant security measures need to be across the depth and breadth of the computing and network stacks of the entities and systems.

PQC-readiness assessment is the process of determination of such quantum-unsafe cryptography usage in the system and during its runtime, and lifetime. This process needs to determine if a system is using any of the capabilities described in the previous section, and if so for what kind of use-cases and cryptography operations.

PQC-readiness assessment is different than the regular security assessment techniques and approaches. Regular security assessment often assume that cryptography schemes and protocols are unbroken with the exception that there are vulnerabilities in the implementation, configuration and adoption such as they are prone to side-channel attacks. Thus they focus on vulnerability-driven assessments (such as CVE-based) leading to risk analysis and remediation. In PQC-readiness assessment, it is known that certain cryptography protocols

3.1. Research Challenges of PQC-Readiness

Research Question (RQ). *“Is there a cryptography operation that the system carries out or takes part in such that that cryptography operation uses quantum-unsafe cryptography scheme(s) or security parameters that are quantum-unsafe, or uses quantum-safe cryptography schemes in a quantum-unsafe manner at least once during the computation or communication?”*

If this question evaluates to True, then such a system cannot be termed as PQC-ready, or quantum-safety-ready especially for that specific use-case/cryptographic operation. By use-case, we refer to a specific scenario or capability in which the system will be used.

An asset is PQC-ready or quantum-safe-ready if it employs, or is has been implemented, configured and is running with quantum-safe cryptography such as PQC or quantum-resistant cryptography, and is ready to be used with low risk of threat from CRQCs.

An entity maybe PQC-ready for certain use-cases, but may not be PQC-ready for other usecases. For example, a system maybe using quantum-safe ciphersuites as part of TLS-1.3 to connect with other quantum-safe endpoints. However, the system maybe encrypting data on the disk using quantum-unsafe cryptography schemes.

“Provably quantum-safe” state of systems. A state that can be proven to be quantum-safe, and its use is “not unsafe”.

PQC-ready state of a system. A system is in a PQC-ready state for a specific use-case if and only if the system is developed, deployed, configured and used in a manner such that all the cryptography operations that maybe carried out by the system in order to support that specific usecases and all other usecases that it is dependent on, are quantum-safe cryptography operations. Whether a system is in a PQC-ready state for all its usecases or for only certain usecases is the problem to be addressed.

Types of PQC-Readiness States. There are four types of states across the lifetime of a program that carries our cryptography operations: (i) static PQC-readiness, (ii) startup/load-time PQC-readiness, (iii) runtime PQC-readiness, (iv) shutdown/unload-time PQC-readiness. Static assessment refers to the development, installation, configuration and deployment time PQC-readiness states. Load-time readiness refers to the time when a given system is loaded into memory and started. Runtime PQC-readiness is about the cryptography operations being carried out during the runtime and whether they are quantum-safe or not. Shutdown/unload-time PQC-readiness refers to during the unload-time - when the program is in the process of shutdown and the cryptography operations during the shutdown and “unload-time” need to be quantum-safe, and are they quantum-safe?

Across the Depth of the Computing Stack. Across the computing stack, there are (L1) hardware, (L2) firmware, (L3) operating systems, (L4) network, (L5) storage, (L6) data, (L7) middleware and (L8) applications layers. For virtualized systems such as cloud VMs and containers, L3 refers to three sublayers - (L3-1) host OS, (L3-2) Virtualization layer, (L3-3) Guest OS layer, which hosts the remaining layers. AI/ML components are in the data, middleware and application layers. Each layer supports cryptography schemes, and uses them as needed.

Across the Breadth of the Computing Network. Public key infrastructure is essential for not only trusted execution of programs and their attestation, but also for trusted network communications, distributed and decentralized computations across the network. Digital certificates are key to establish the root of trust in the digital world. They are under threat from Shor’s algorithm and GEECM.

Observability and Runtime. Runtime PQC-readiness state is the highest priority one as the cryptography operations are carried out by the system during runtime; it also engages in cryptography operations with other components on the same system or on a distributed system across the network. Therefore, our approach focuses on observability-based PQC-readiness for runtime operations.

Holistic PQC-readiness Assessment. In order to solve the research question RQ, and transition a system to a quantum-safe state, holistic readiness assessment for quantum-safe states is needed. A holistic assessment analyzes across the depth, breadth of the computing infrastructure for individual and distributed networked components in a static and dynamic manner to assess the PQC-readiness states across

the lifecycle of the programs. That enables determinations of the vulnerable, or weak cryptography schemes, with respect to the quantum threats.

3.2. Quartz: Observability and PQC-Readiness

We addressed some of the research challenges that we implemented in a research prototype called Quartz [1]. Our approach uses observability among other techniques for PQC-readiness assessment. A brief description of Quartz follows.

Quartz supports PQC readiness at some level for the following: (i) network connections during their establishment phase, (ii) API connections, (iii) file systems and file vaults, (iv) database security, (v) SQL queries, (vi) code and code repository, (vii) cloud storage, (viii) cloud application using containers, (ix) cloud security configuration.

Quartz analyzes details of the assets, APIs to access observability information, to what depth and breadth the PQC-readiness assessment is to be carried out. Based on that, it is determined if an asset uses cryptography or takes part in a cryptography operation? If there is usage of cryptography, then it is necessary to determine statically if the cryptography schemes and protocols are quantum-safe or not. Does the system employ any of the PQ parameters as described earlier (Section 2.4).

Quartz generates *ciphersuite dependency graphs* (CDG) for an asset statically, or dynamically as needed. For a network communication, it computes the CDG for the client as well as the server. The dependency graph is then used to determine if the two parties or the asset have any quantum-safe ciphersuites configured to be used or not. From the ciphersuite dependency graph, we determine the risk of the ciphersuites used using a "PQC scheme and protocol management" subsystem. This subsystem stores and manages the PQ cryptography algorithms, protocols, quantum-unsolvable problems they address, and their quantum-safety states, and associated risks. Using the dependency graph, the system generates the cryptography supply chain and the cryptography bill of materials. It then analyzes the risk of the dependency graph and computes a risk of a given ciphersuite to PQC-readiness.

Static and dynamic analysis are carried out for each asset that needs to be assessed. Static analysis is carried out over the code repositories, static and binary code, configuration of systems such as configuration management databases, asset descriptions. Dynamic assessment is carried out on observability MELT (metrics, events, logs and traces) data for processes and related cryptographic operations in runtime.

3.3. Discussion

Measurement and monitoring of all the parameters for PQC-readiness mentioned in the Section 2.4 in a holistic manner is hard. Moreover, analysis of an asset for each of the aspects mentioned in this section 3.1 and in holistic manner are insecure. Moreover, another key challenge is determination of cryptography schemes being used, type

of cryptography being used, the libraries and security parameters. How different ciphersuites are dependent on each other and what is the cryptography supply chain for an asset needs to be addressed. One questions worth noting is: is the research question RQ decidable, or specifically, for any general system as an asset, is the determination of PQC-readiness state σ of a system S over a period of time δt for all use-cases U of S is *True* undecidable?

4. Conclusions and Future Work

We have studied the problem of adoption of post-quantum cryptography and assessment of the PQC-readiness of an asset in holistic manner. We briefly discussed the research challenges as well as our approach for the assessment using ciphersuite dependency graphs and observability. A number of research challenges are discussed that need to be addressed for better quantum threat assessment and remediation.

References

- [1] *Quartz: Quantum Risk and Threat Analyzer*, 2023. <https://github.com/cisco-open/Quartz>.
- [2] *NIST Releases First 3 Finalized Post-Quantum Encryption Standards*, August 13 2024. <https://www.nist.gov/news-events/news/2024/08/nist-releases-first-3-finalized-post-quantum-encryption-standards>.
- [3] *NIST Selects HQC as Fifth Algorithm for Post-Quantum Encryption*, March 11 2025. <https://www.nist.gov/news-events/news/2025/03/nist-selects-hqc-fifth-algorithm-post-quantum-encryption>.
- [4] *NIST IR 8547 (Initial Public Draft): Transition to Post-Quantum Cryptography Standards*, November 12, 2024. <https://csrc.nist.gov/pubs/ir/8547/ipd>.
- [5] Daniel J Bernstein, Nadia Heninger, Paul Lou, and Luke Valenta. Post-quantum rsa. In *Post-Quantum Cryptography: 8th International Workshop, PQCrypto 2017, Utrecht, The Netherlands, June 26-28, 2017, Proceedings* 8, pages 311–329. Springer, 2017.
- [6] Ethan Bernstein and Umesh Vazirani. Quantum complexity theory. In *Proceedings of the twenty-fifth annual ACM symposium on Theory of computing*, pages 11–20, 1993.
- [7] Lov K Grover. A fast quantum mechanical algorithm for database search. In *Proceedings of the twenty-eighth annual ACM symposium on Theory of computing*, pages 212–219, 1996.
- [8] David Joseph, Rafael Misoczki, Marc Manzano, Joe Tricot, Fernando Dominguez Pinuaga, Olivier Lacombe, Stefan Leichenauer, Jack Hidary, Phil Venables, and Royal Hansen. Transitioning organizations to post-quantum cryptography. *Nature*, 605(7909):237–243, 2022.
- [9] Peter W Shor. Algorithms for quantum computation: discrete logarithms and factoring. In *Proceedings 35th annual symposium on foundations of computer science*, pages 124–134. Ieee, 1994.
- [10] Peter W Shor. Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer. *SIAM review*, 41(2):303–332, 1999.